Vulnerability Assessment Report

Passive Web Security Assessment of
https://demo.testfire.net/

Prepared by	Melakeselam Lawayew
Program	Future Interns - Cybersecurity
Task	Task 1 - Web Application Vulnerability Assessment
Report date	October 12, 2026
Assessment type	Passive (non-intrusive); no exploitation performed

1. Executive Summary

I assessed **https://demo.testfire.net/**, a public demo web application built for security training, using only passive methods. I browsed the site, captured its HTTP responses with OWASP ZAP, reviewed the passive alerts ZAP raised, and checked the site's TLS certificate with OpenSSL.

The work produced nine documented findings. **The only issue I confirmed directly is that the TLS certificate expired on June 21, 2026**, which means browsers and other clients that validate certificates can warn users or refuse the connection. The other eight come from ZAP's passive scan: five missing or weak security headers, a session cookie without a SameSite attribute, a server version disclosure, and two informational notes. These are configuration weaknesses. **Nothing was exploited**, and this report does not claim the site was compromised.

The response ZAP captured contained only five headers (Server, Set-Cookie, Content-Type, Date, content-length), so none of the security headers discussed below were present. The recommended priorities are: renew the certificate first, then add CSP, anti-clickjacking, HSTS and X-Content-Type-Options headers, add SameSite to the session cookie, and stop advertising the server version.

Summary of findings

ID	Finding	Rating	Source
WEB-01	Expired TLS certificate	**High (priority remediation)**	OpenSSL
WEB-02	Content Security Policy (CSP) header not set	**Medium**	ZAP 10038
WEB-03	Anti-clickjacking header missing	**Medium**	ZAP 10020
WEB-04	Session cookie without SameSite attribute	**Low**	ZAP 10054
WEB-05	Server version disclosed in Server header	**Low**	ZAP 10036
WEB-06	HSTS header not set	**Low**	ZAP 10035
WEB-07	X-Content-Type-Options header missing	**Low**	ZAP 10021
WEB-08	Cache-Control directives need review	**Informational**	ZAP 10015
WEB-09	Session management cookie identified	**Informational**	ZAP 10112

ZAP listed eight alert types; WEB-01 is the ninth finding and comes from the OpenSSL check. Ratings are preliminary judgements from passive observations, not a formal CVSS score.

2. Scope and Rules of Engagement

In scope: https://demo.testfire.net/ - the home page and the responses seen while browsing it - plus its TLS configuration on port 443.

Out of scope: other domains and systems, logged-in areas, brute forcing, denial of service, and any exploitation.

Approach: the target is a public demo application meant for security learning. I used only passive techniques: normal browsing, reading response headers, ZAP's passive scan rules, and one standard TLS handshake to read the certificate. No attack payloads were sent and no active scan was run.

3. Methodology

- **Reconnaissance:** browsed the site and looked at the HTTP response headers.
- **Passive scanning:** sent the traffic through OWASP ZAP 2.17.0 in passive mode and reviewed each alert.
- **TLS check:** read the certificate with OpenSSL to confirm its validity dates.
- **Documentation:** recorded each finding with its evidence, impact and fix, and saved a screenshot for each.

Tools

Tool	Used for
Web browser	Manual inspection of the site and its headers
OWASP ZAP 2.17.0 (passive)	Detecting header, cookie and caching issues
OpenSSL on Kali Linux	Verifying the TLS certificate dates

Response observed by ZAP

ZAP captured this response from the home page on 12 Oct 2026. It carries the session cookie and the Server header, and none of the security headers covered in this report:

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=[redacted]; Path=/; Secure; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Date: Mon, 12 Oct 2026 20:46:17 GMT
content-length: 9227
```

4. Detailed Findings

WEB-01 - Expired TLS Certificate	**High (priority remediation)**

Target	demo.testfire.net:443
Check	OpenSSL, run from Kali Linux
Issuer	Sectigo RSA Domain Validation Secure Server CA
Valid until	Jun 21 23:59:59 2026 GMT

Evidence

I ran the following command and read the certificate dates:

```
echo | openssl s_client -connect demo.testfire.net:443 -servername demo.testfire.net 2>/dev/null |
  openssl x509 -noout -subject -issuer -dates
```

The certificate was valid from May 21, 2025 and ran out on June 21, 2026. On the assessment date, October 12, 2026, it had been expired for almost four months.

What it means

The server is presenting a certificate that is no longer valid. This is the one finding confirmed directly by a command-line check rather than inferred from a scanner alert.

Potential impact

Clients that check certificates can show security warnings or block the HTTPS connection. Users also get used to clicking through warnings, which weakens the protection TLS is meant to give.

Recommendation

Renew and install a valid certificate, confirm the full chain is served, and set up automatic renewal with expiry monitoring.

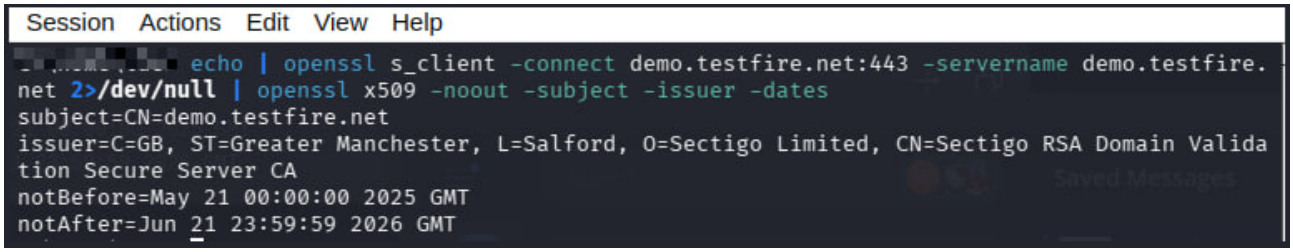


Figure 1: OpenSSL output showing notAfter = Jun 21 23:59:59 2026 GMT.

WEB-02 - Content Security Policy (CSP) Header Not Set | Medium

ZAP alert	Content Security Policy (CSP) Header Not Set
Risk / Confidence	Medium / High
CWE / WASC	693 / 15
Plugin	10038 (passive)

Evidence

ZAP reported that the response has no Content-Security-Policy header, which the captured headers in Section 3 confirm.

What it means

A CSP tells the browser which sources it may load scripts, styles, images and frames from. It acts as a second line of defence against cross-site scripting and content injection.

Potential impact

With no policy, the browser applies no site-defined limits, so an injection flaw, if one exists, would be easier to abuse. The missing header does not by itself prove such a flaw is present.

Recommendation

Deploy a CSP that fits the application. Start strict (for example default-src 'self'), loosen only where needed, and test in report-only mode first.

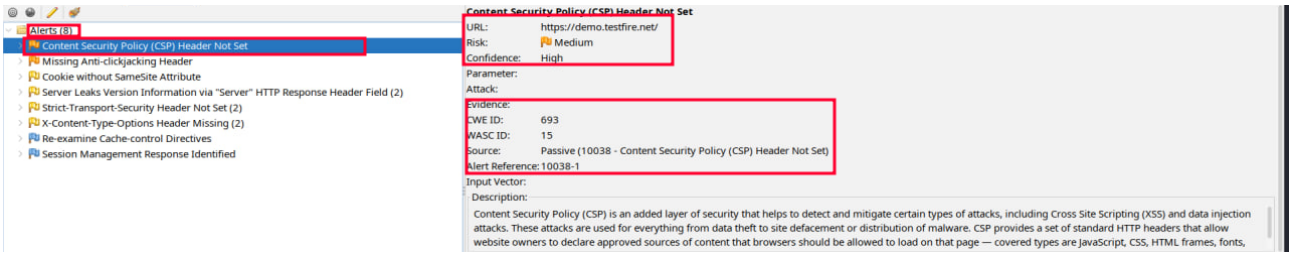


Figure 2: ZAP alert: CSP Header Not Set (Risk Medium, Confidence High).

WEB-03 - Anti-Clickjacking Header Missing | Medium

ZAP alert	Missing Anti-clickjacking Header
Risk / Confidence	Medium / Medium
Parameter	x-frame-options
CWE / WASC	1021 / 15
Plugin	10020 (passive)

Evidence

ZAP found neither an X-Frame-Options header nor a CSP frame-ancestors directive in the response.

What it means

These controls decide whether other websites may display the page inside a frame. Without them, the page can be framed by any site.

Potential impact

An attacker could place the page in a hidden frame and trick a visitor into clicking something on it (clickjacking). Whether that matters depends on what actions the page offers.

Recommendation

Add Content-Security-Policy: frame-ancestors 'self', or X-Frame-Options: DENY / SAMEORIGIN.

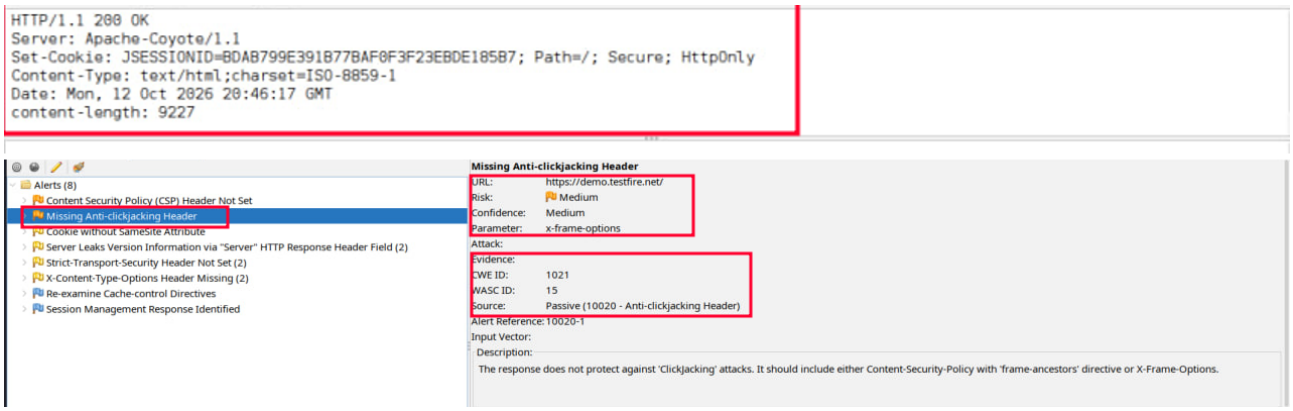


Figure 3: ZAP alert: Missing Anti-clickjacking Header (Risk Medium, Confidence Medium).

WEB-04 - Session Cookie Without SameSite Attribute	**Low**

ZAP alert	Cookie without SameSite Attribute
Risk / Confidence	Low / Medium
Parameter	JSESSIONID
CWE / WASC	1275 / 13
Plugin	10054 (passive)

Evidence

The JSESSIONID cookie is set with Secure and HttpOnly, but with no SameSite attribute (Set-Cookie: JSESSIONID).

What it means

SameSite controls whether the browser sends the cookie on cross-site requests. When it is absent, the result depends on each browser's default.

Potential impact

It can increase exposure to cross-site request forgery in some browsers or setups. It does not prove that CSRF is possible on this site.

Recommendation

Set SameSite=Lax or Strict on the session cookie, in addition to Secure and HttpOnly.



Figure 4: ZAP alert: Cookie without SameSite Attribute (Risk Low, Confidence Medium).

WEB-05 - Server Version Disclosed in Server Header — Low

ZAP alert	Server Leaks Version Information via "Server" HTTP Response Header Field (2 instances)
Risk / Confidence	Low / High
Evidence	Server: Apache-Coyote/1.1
CWE / WASC	497 / 13
Plugin	10036 (passive)

Evidence

Every response includes the header `Server: Apache-Coyote/1.1`, which names the Java application server stack and its version. ZAP reported two instances, consolidated here as one finding.

What it means

Version banners make it easier to map the technology in use. By themselves they are not a vulnerability.

Potential impact

An attacker can search for known weaknesses in that exact software and version. The risk is low and depends on how current the software is.

Recommendation

Suppress or genericise the Server header, and keep the application server patched either way.

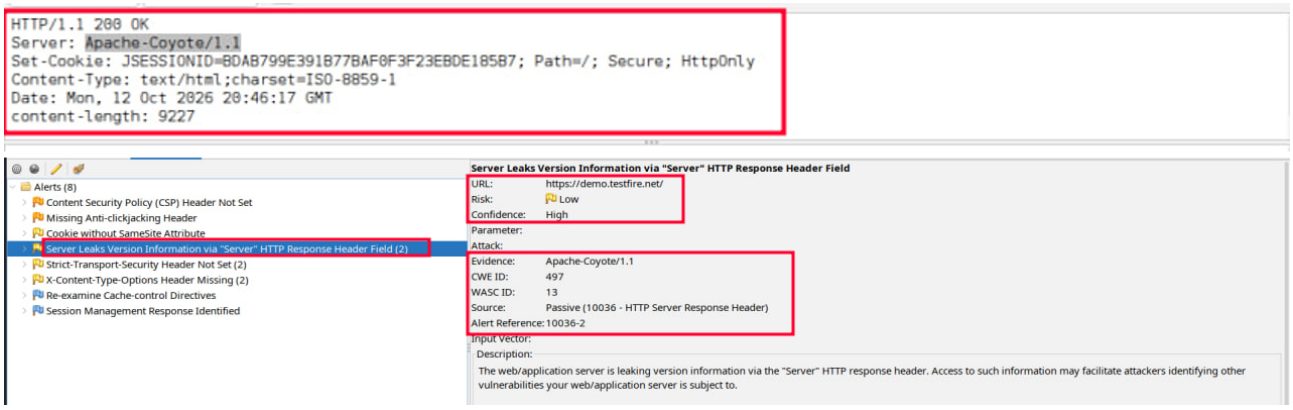


Figure 5: ZAP alert: Server header leaks version (Evidence Apache-Coyote/1.1, Confidence High).

WEB-06 - HSTS Header Not Set | Low

ZAP alert	Strict-Transport-Security Header Not Set (2 instances)
Risk / Confidence	Low / High
CWE / WASC	319 / 15
Plugin	10035 (passive)

Evidence

The response has no Strict-Transport-Security header. ZAP reported two instances, consolidated here.

What it means

HSTS tells browsers to use only HTTPS for the site for a set period, which helps against protocol downgrade and some man-in-the-middle attacks.

Potential impact

Without it, a first visit or a stripped connection may go over plain HTTP, giving a network attacker a chance to read or alter traffic.

Recommendation

Once a valid certificate is installed (WEB-01), send Strict-Transport-Security with a suitable max-age, for example max-age=31536000; includeSubDomains.

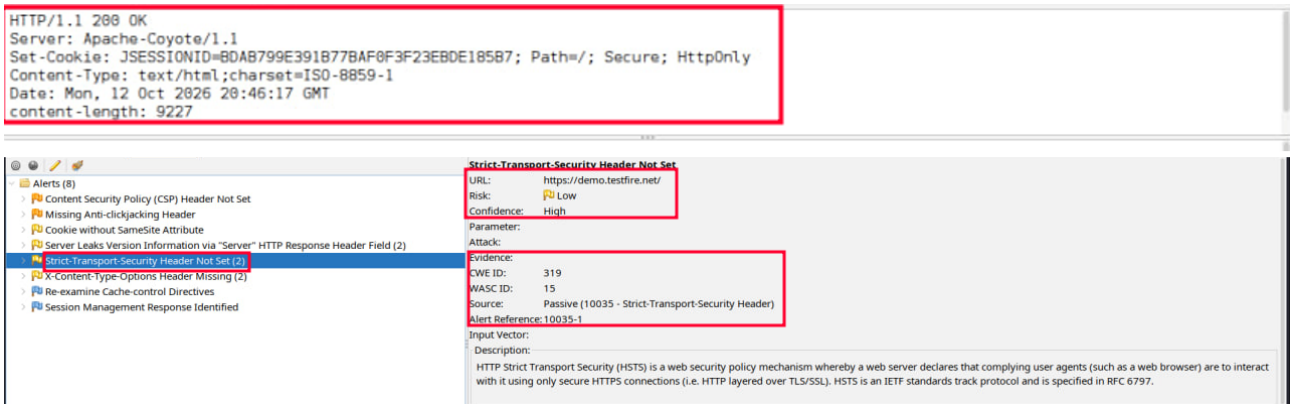


Figure 6: ZAP alert: Strict-Transport-Security Header Not Set (Risk Low, Confidence High).

WEB-07 - X-Content-Type-Options Header Missing	**Low**

ZAP alert	X-Content-Type-Options Header Missing (2 instances)
Risk / Confidence	Low / Medium
Parameter	x-content-type-options
CWE / WASC	693 / 15
Plugin	10021 (passive)

Evidence

The response does not set X-Content-Type-Options: nosniff. ZAP reported two instances, consolidated here.

What it means

The header stops browsers from guessing a response's content type and makes them follow the declared one.

Potential impact

In some situations MIME sniffing lets a browser treat content as a different type than declared, which adds risk when combined with wrong content types or injection flaws. The missing header alone does not prove an attack is possible.

Recommendation

Set the correct Content-Type on responses and add X-Content-Type-Options: nosniff everywhere, including error pages.

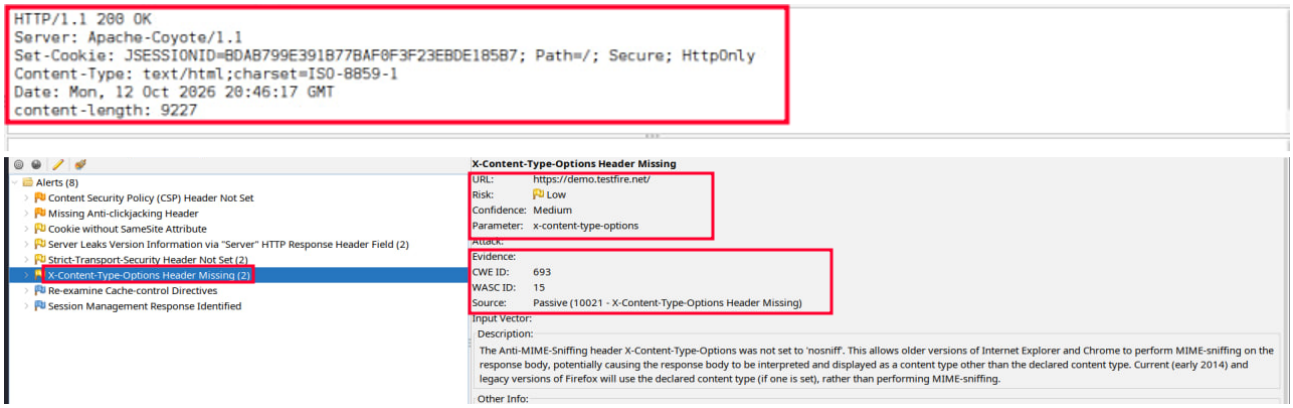


Figure 7: ZAP alert: X-Content-Type-Options Header Missing (Risk Low, Confidence Medium).

WEB-08 - Cache-Control Directives Need Review | Informational

ZAP alert	Re-examine Cache-control Directives
Risk / Confidence	Informational / Low
Parameter	cache-control
CWE / WASC	525 / 13
Plugin	10015 (passive)

Evidence

ZAP flagged that no Cache-Control header is set on the response, which the captured headers confirm.

What it means

Caching suits static files such as CSS, JavaScript and images, but pages with private content should not be stored by browsers or proxies longer than intended.

Potential impact

Private content could stay available longer than intended if it were cached in a shared or unsuitable place. This alert has Low confidence and does not show that anything sensitive was cached.

Recommendation

Review caching per resource type: use Cache-Control: no-store for sensitive responses, and public with max-age for static assets.



Figure 8: ZAP alert: Re-examine Cache-control Directives (Informational, Confidence Low).

WEB-09 - Session Management Cookie Identified — Informational

ZAP alert	Session Management Response Identified
Risk / Confidence	Informational / Medium
Parameter	JSESSIONID
Plugin	10112 (passive)

Evidence

ZAP identified JSESSIONID as the session token (Other Info: cookie:JSESSIONID).

What it means

A session cookie is normal for a web application and is not a weakness in itself. Its safety depends on its attributes and on how sessions are created, validated and ended.

Potential impact

None on its own. It is useful context for WEB-04.

Recommendation

No fix is needed for this alert. As part of the wider cookie review, confirm Secure, HttpOnly and SameSite are all set.

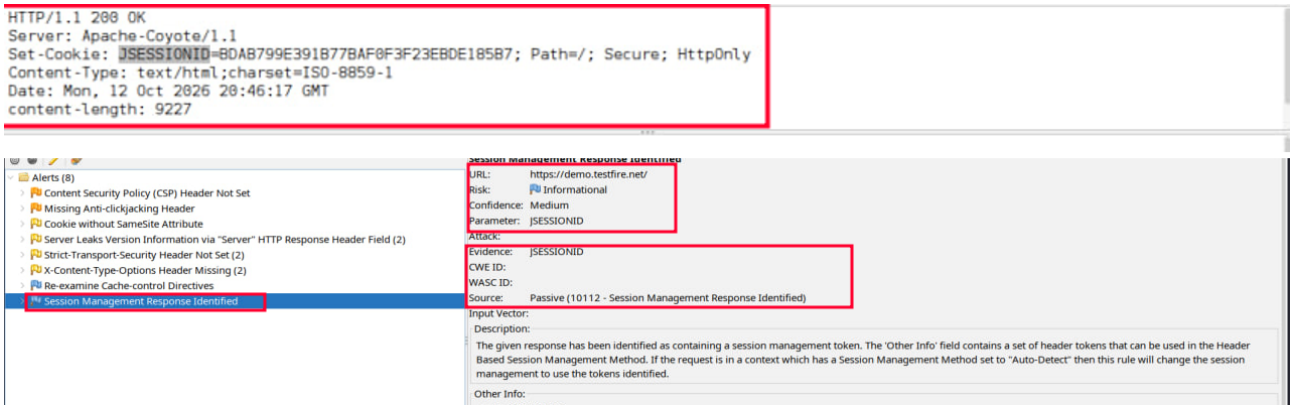


Figure 9: ZAP alert: Session Management Response Identified (Informational, Confidence Medium).

5. Remediation Priorities

Priority	Action	Addresses
1 - Immediate	Renew and install a valid TLS certificate; add expiry monitoring	WEB-01
2 - Short term	Add CSP and anti-clickjacking protection	WEB-02, WEB-03
3 - Short term	Enable HSTS once the certificate is valid; add SameSite to the session cookie; add X-Content-Type-Options	WEB-04, WEB-06, WEB-07
4 - Hardening	Hide the server version; review caching by resource type	WEB-05, WEB-08
5 - Review	Check session cookie protections as a whole	WEB-09

6. Limitations

- The assessment was passive and limited to the home page and the responses seen while browsing. It is not a full penetration test.
- Passive alerts point to possible configuration weaknesses. None was exploited, so none is proof of a successful attack.
- Ratings are preliminary and are not a formal risk calculation.
- Alerts that ZAP reported on more than one instance were merged into a single finding.
- Logged-in areas, business logic and server-side vulnerabilities were not tested.

7. Conclusion

Passive testing of demo.testfire.net confirmed one clear problem, an expired TLS certificate, and showed that the site is missing several standard browser-security headers and a cookie attribute while revealing its server version. Renewing the certificate and then adding the recommended headers would noticeably improve the site's baseline security. A short re-test after the fixes would confirm they work.

Prepared by Melakeselam Lawayew - Future Interns, Cybersecurity - October 12, 2026